

无线传感器网络中基于 PUF 的轻量级 多网关身份认证协议^{*}

王 雄^a, 王文博^a, 刘 昂^{b†}, 许盛伟^c, 李伟麟^a, 张泽昊^a

(北京电子科技学院 a. 网络空间安全学院; b. 网络信息化管理处; c. 信息安全研究所, 北京 100070)

摘 要: 针对无线传感器网络中多网关身份认证协议所存在的计算效率低、缺乏安全性以及无线传感器资源受限等问题,提出了一种基于不可克隆函数(PUF)的轻量级多网关身份认证协议。该协议全部使用异或、哈希函数等轻量级运算保证加密传输和完整性验证,每个设备利用 PUF 函数生成“设备指纹”标志其唯一性,并且通过提出的网络架构能够解决网关节点计算瓶颈和单点故障问题。其次通过随机预言模型、ProVerif 协议仿真工具和非形式化安全分析,证明了所提协议满足信息传输机密性、完整性、匿名性等 14 种安全属性。最后在统一性能基准下通过与近年相关协议进行分析对比,结果表明所提协议在效率、存储成本和安全属性方面具有较大的优势。

关键词: 不可克隆函数; 轻量级; 多网关; 身份认证协议

中图分类号: TN918.9

文献标志码: A

文章编号: 1001-3695(2025)04-036-1230-09

doi: 10.19734/j.issn.1001-3695.2024.06.0249

Lightweight PUF-based multi-gateway authentication protocol for wireless sensor network

Wang Xiong^a, Wang Wenbo^a, Liu Ang^{b†}, Xu Shengwei^c, Li Weilin^a, Zhang Zehao^a

(a. Dept. of Cyberspace Security, b. Network & Information Management Division, c. Institute of Information Security, Beijing Electronic Science & Technology Institute, Beijing 100070, China)

Abstract: To address issues such as low computational efficiency, lack of security, and limited resources in wireless sensor networks, this paper proposed a lightweight multi-gateway authentication protocol based on PUF. This protocol utilized only lightweight operations such as XOR and hash functions to ensure encrypted transmission and integrity verification. Each device generated a unique “device fingerprint” using the PUF function to identify its uniqueness. The proposed network architecture solved the computational bottleneck and single point of failure issues at gateway nodes. Additionally, this paper demonstrated that this protocol meets 14 security attributes, including confidentiality, integrity, anonymity of information transmission, and so on, through the random oracle model, ProVerif protocol simulation tool, and informal security analysis. Finally, under a unified performance benchmark, this paper compared and analyzed this protocol against recent related protocols, showing significant advantages in efficiency, storage cost, and security attributes.

Key words: physical unclonable function (PUF); lightweight; multi-gateway; authentication protocol

0 引言

物联网(Internet of Things, IoT)是一种新兴的数字通信网络。物联网技术的迅猛发展使得无线传感器网络(wireless sensor network, WSN)在远程医疗、工业自动化、智能农业等领域展现出日益凸出的重要性。然而,WSN 的开放性与分布式特性亦伴随着一系列安全挑战,尤其是在身份认证与密钥协商环节。由于传统的单网关身份验证协议计算消耗量大、易受攻击、故障冗余机制不够完善以及缺乏灵活性等不足,已难以满足现代 WSN 对效率、安全性、可靠性以及可扩展性的高要求。

近年来,为满足 WSN 一系列的不足和挑战,研究人员提出了许多基于密码学源语的身份认证协议。但许多协议仅依赖

于密码安全性,容易受到脱机密码猜测攻击。为了避免这些问题,研究人员接连提出了基于密码和智能卡的双因素身份验证协议。2009 年,Das^[1]建立了一种新颖的双因素身份验证方案,其中用户拥有密码和智能卡。同年,Nyang 等人^[2]指出文献[1]容易受到脱机密码猜测攻击,并提出了克服此缺点的解决方法。2010 年,Cheikhrouhou 等人^[3]提出了一种基于对称算法高级加密标准(advanced encryption standard, AES)的轻量级身份验证方案,使用了互相认证和密钥建立机制来确保协议的机密性和数据完整性。基于公钥算法的方案可以实现比基于对称算法的方案更多的安全属性,但它们也会消耗更多的系统资源。2011 年,Yeh 等人^[4]发现文献[5]未能提供安全的用户密码更新方法,并容易受到内部攻击的影响。为了解决

收稿日期: 2024-06-10; 修回日期: 2024-07-25 基金项目: 国家自然科学基金资助项目(62176273); 中央高校基本科研业务费专项资金资助项目(3282024026, 3282023015)

作者简介: 王雄(1977—),男,河北保定人,副教授,硕士,主要研究方向为密码协议、密码系统等;王文博(1999—),男,甘肃天水人,硕士研究生,主要研究方向为远程医疗中的身份认证协议和漏洞挖掘;刘昂(1988—),男(通信作者),湖北洪湖人,工程师,博士,主要研究方向为网络空间安全、密码学(liuang0826@163.com);许盛伟(1976—),男,江西吉安人,教授,博导,博士,主要研究方向为网络信任体系、密码应用;李伟麟(2001—),男,河北衡水人,硕士研究生,主要研究方向为身份认证协议;张泽昊(2000—),男,安徽临泉人,硕士研究生,主要研究方向为物联网安全、身份认证协议。

这些现有问题,他们首先应用了椭圆曲线密码算法(elliptic curve cryptography, ECC)和智能卡来构建 WSN 身份验证协议。2013 年,文献[6]建立了一个身份验证协议,以实现完美的前向保密性与用户和传感器节点之间的互相认证和密钥协商。Choi 等人^[7]指出文献[6]容易受到会话密钥攻击、盗窃智能卡等攻击的影响,并改进了出现的安全问题。基于 ECC 的身份验证协议是用于改善射频识别(radio frequency identification, RFID)系统安全性和隐私性的方法之一。Dinarvand 等人^[8]检验并比较了利用该方法建立安全性的协议,并提出了一种使用 ECC 进行相互认证的 RFID 身份验证协议,以克服现有方案的弱点。2021 年,Wang 等人^[9]利用 ECC 提出了增强的匿名身份验证方案,用于智能医疗保健系统。2022 年,文献[10]提出了一种轻量级的用于基于物联网的 WSN 的身份验证协议。文献[11]提出了一种基于区块链平台的 IoT 环境的三因素认证方案。

文献[5]首次提出了基于两因素的多网关身份验证和密钥协议,用于 WSN,能够确保用户匿名性,同时抵抗密码猜测攻击、内部攻击等。同年,Das 等人^[12]指出文献[5]无法保护用户匿名性,此外,还容易受到密码猜测攻击和身份猜测攻击的影响。之后,文献[12]提出了一个基于 AES 算法的三因素身份验证协议来解决这些问题。此外,Wu 等人^[13]指出文献[5]也无法抵抗跟踪攻击,并且没有一个共同的三方会话密钥。Guo 等人^[14]发现文献[13]无法抵抗脱机密码猜测攻击和身份猜测攻击,并且容易受到内部特权攻击、用户跟踪等攻击的影响。为解决文献[13]的安全问题,Guo 等人^[14]在其基础上提出了一种多网关 WSN 的三因素身份验证协议。在 2017 年,Srinivas 等人^[15]详细分析了文献[5],并提出了改进的三因素身份验证协议。然而,Wang 等人^[16]发现文献[15]同样容易受到智能卡盗窃攻击、节点捕获攻击和跟踪攻击的影响,并且无法保证前向保密性。2019 年,Lee 等人^[17]提出了一种适用于多网关协议的三因素相互认证协议,其中如果用户希望使用所有传感器节点,则需要所有网关节点注册。2022 年,Dai 等人^[18]发现文献[14]容易出现单点故障,并提出了一种基于 ECC 的多网关 WSN 的新型三因素认证方案,实现了智能卡吊销、动态传感器节点添加,并能够抵御单点故障。Zhao 等人^[19]提出了一种基于 ECC 的新型三因素身份验证和密钥协议,适用于 IoT 环境,在单网关环境中可以使用其方案,并可以扩展到多网关环境。2023 年,Chen 等人^[20]提出了基于密码和智能卡的两因素多网关身份验证协议,能够抵抗密码和身份猜测以及智能卡丢失攻击。大多数方案利用 ECC 算法来确保它们可以实现更多的安全属性。然而,ECC 提供更多的安全性,同时产生更多的计算开销。

目前面向无线传感器网络中的密钥协商协议大多以单网关为主,少数使用多网关或者多网关相互协作,此外多网关也无法达到轻量级。其中单网关作为可信机构负责普通用户和传感器设备的注册、信息传递和密钥协商等。而多网关则仍然借助一个可靠中心节点网关负责注册等其他功能。在目前无线传感器网络中使用的网络结构无论是单网关或多网关,在中心网关节点发生故障时都没有其他备用网关可以保障系统的正常运行,并无法通过多个网关实现负载均衡。所以设计一种既能够实现故障备用,也能实现负载均衡的网络结构,并提出一种可行安全的协议变得尤为重要。

为改进上述不足,本文提出了一个基于 PUF 的轻量级多网关身份认证与密钥协商方法,旨在为 WSN 构建一个更为高效、安全、可靠且具备良好扩展性的身份验证方法。该方法充分利用 PUF 的不可预测性与不可克隆性特点,结合轻量级计算技术与多网关架构,设计出了一项既安全又高效的密钥协

商协议。本文主要工作如下:a)提出了一个基于 PUF 的轻量级多网关身份认证与密钥协商协议。该协议中,全部使用哈希运算、异或和 PUF 函数等轻量级密码源语,用户和网关、网关和传感器通过使用轻量级运算进行加密传输重要参数,极大地降低了该协议的计算开销;b)使用随机预言模型、ProVerif 仿真工具对协议进行了形式化安全证明,确保了会话密钥的安全性。同时,非形式化安全分析表明,该协议可以抵御常见攻击和特定漏洞,比如口令猜测攻击、临时秘密值泄露攻击、节点捕获攻击等,且具有前向/后向安全等属性,同时满足三因子安全性;c)在统一基准下与近年相关协议在计算开销、通信开销、存储开销和安全性方面进行对比。结果表明,该协议在计算效率、存储开销和安全性方面具有优势,适合在资源受限环境中部署。

1 基础知识

1) 生物哈希函数 BioHashing()

生物哈希(biometric hashing)函数是一种专门用于处理生物识别数据的哈希函数,可将个人生物特征(如指纹、虹膜图案等)转换为固定长度的哈希值。生物哈希函数对输入的生物特征的微小差异敏感。

2) 物理不可克隆函数 PUF()

PUF()函数是一种基于物理世界的唯一性和不可复制性所实现的安全机制。其核心思想为利用集成电路制造过程中产生的微小物理差异来产生唯一的且不可克隆的验证标识。

2 相关描述

2.1 协议框架

目前在无线传感器网络中,密钥协商虽然仍以单网关为主,但随着外部环境的变化,不断增加的传感器节点数量以及对效率的要求等问题,使得单网关已无法适应现存的一些挑战。为了应对单网关所存在的问题,不断有研究人员提出一些基于多网关的身份认证与密钥协商协议,但大多协议中多网关之间的数据没有共享,且完成一次会话密钥协商需要多个网关共同完成,虽然可以应对传感器数量不断增加的问题,但其本质仍是单网关。所以为了满足实际需求,本文在其基础之上设计了一种多网关框架结构,如图 1 所示。该框架涉及多个网关,网关与网关之间通过安全信道连接,两两互通,并且每个网关中保存的数据一致,任何一个网关都可单独完成一次会话密钥协商。除此之外,网关间使用已存在的数据转发和通信策略进行数据转发和通信,并规定某一网关为主网关,所以能够更好地集中于考量身份认证和密钥协商的过程上,即协议本身。

2.2 应用场景

在所设计的框架基础上,提出了一个无线传感器网络中基于 PUF 的轻量级多网关身份认证协议,该协议涉及用户、可信网关以及传感器设备三个实体。在实际应用场景中,用户需要访问或控制传感器设备。在用户与传感器交互前,用户和传感器都需通过安全信道向可信网关进行注册。当主网关收到注册信息之后,会将注册信息共享至其他网关并保存。注册完成后,用户通过终端设备首先进行本地身份验证,然后借助可信网关与传感器协商出一个会话密钥。协商过程中,当主网关中央处理单元(central processing unit, CPU)使用率超过 75% 时或发生故障时,可通过已存在的数据转发和通信传输策略将其所接收到的消息转至其他任一备用网关进行运算,以免节点故障导致系统的瘫痪。密钥协商完成后,用户与传感器设备

利用会话密钥对传输数据进行加密,以实现数据安全传输的目标。大致过程如图 1 所示,图中虚线表示公共信道,实线表示私有信道。

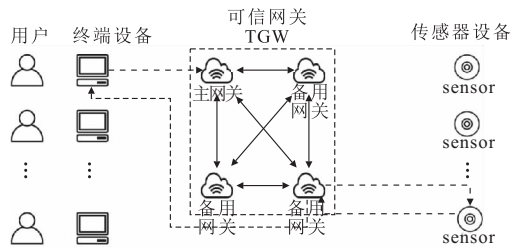


图 1 网络结构
Fig. 1 Network structure

2.3 协议优点

提出的无线传感器网络中基于 PUF 的轻量级多网关的身份认证与密钥协商协议,具有无线传感器中轻量级的优点,同时也基于 PUF 技术解决了身份认证信息泄露、用户身份追踪、会话密钥不可伪造等问题,在资源受限的传感器节点保持了较高的计算效率,并基于会话密钥建立后续安全传输通道。

本文协议在身份认证中有着非常高的安全强度。在普通用户中,利用 PUF 的特性,本文将用户的生物信息经过 PUF 的处理生成唯一且不可克隆的信息,使得攻击者即使在获得用户的 ID、口令、生物特征和智能卡参数的前提下依然无法通过已获取的信息在另一台移动设备上登录和假冒合法用户,也无法伪造出合法的 M_1 ,其具备 $n-1$ 因素安全特征。此外,基于 PUF 的特性,即使用户端、传感器端被窃取并分析,仍然无法恢复出之前协商的会话密钥,无法假冒身份计算出后续的会话密钥,适合安全性要求较高的场景。

其次,每个网关均部署了 PUF 函数,利用 PUF 函数生成的数据形成每个网关的“设备指纹”,即挑战应答机制中的响应值,且该指纹不可克隆也不可恢复。而在每次会话协商的过程中,网关的“设备指纹”会通过加密传输给用户设备,用户设备更新此前的数据。网关在收到用户认证更新通过之后,也会通过安全信道将挑战响应对共享至其他网关进行数据更新。所以用户和网关之间、网关与网关之间的数据始终保持同步。

当其中一个网关发生故障时,因每个网关当中所存储的数据一致,只需通过已存在的数据转发和通信策略将其数据信息转发至另一台网关设备,便可使会话密钥协商过程不间断地完成,解决了一个网关环境恶劣情况下单点故障或计算资源消耗极大时的处理瓶颈。

3 提出的协议

本文提出了一个基于 PUF 的轻量级多网关身份认证协议。该协议包括初始化、用户注册、传感器注册、登录和密钥协商、口令更新和用户注销阶段六个阶段。协议使用的符号及其描述参见表 1。

表 1 符号和说明
Tab. 1 Symbols and descriptions

符号	描述
U_i, S_j, TGW	普通用户、传感器设备和可信网关
ID, SD	普通用户和传感器的身份标识
PW, BIO	普通用户的口令和生物特征
C_D, R_D	一对挑战响应对
y	可信网关的长期密钥
T_1, T_2	当前时间戳
r, R	用户、传感器设备生成的随机数
BioHashing()	生物哈希函数
PUF_{GW}	网关中 PUF 函数
PUF_1, PUF_2	用户设备和传感器中的 PUF 函数
$h(\cdot), \oplus, \parallel$	哈希函数、异或和连接符

3.1 初始化阶段

a) 主网关和其他备用网关都建立各自的 $PUF_{GW}()$, 便于后续生成各自的挑战应答机制对。其次主网关生成自己的主密钥 y 并安全共享到其他网关, 保存下来以便传感器注册阶段使用。

b) 建立各个网关之间的安全信道、数据转发和通信策略, 使网关之间两两互通, 安全连接。设定各个网关 CPU 利用率的阈值 75%, 若当前 CPU 超过 75% 时将所接收到的信息转发至下一空闲网关进行运算。

c) 建立数据共享策略, 使其能够快速精准地实现数据定位和数据更新, 达到数据同步的目的。

3.2 用户注册阶段

用户设备注册阶段流程如图 2 所示, 具体步骤如下:

a) 用户在自己想要注册的终端设备上输入自己的身份标识 ID、口令 PW 和生物特征 BIO。随即计算 $B_i = \text{Biohashing}(BIO)$, $E_i = PUF_1(BIO)$, $GPW = h(ID \parallel E_i \parallel PW)$ 和 $HID = h(ID \parallel E_i)$ 。用户设备通过安全信道将 HID 发送至主网关。随后接着计算本地身份验证参数 $Ver = h(GPW \parallel E_i \parallel PW)$, 并将其保存在本地设备中。

b) 主网关收到 HID 后, 随后产生一对挑战应答机制对。即通过产生一个随机数 C_D , 计算出重要参数 $R_D^{new} = PUF_{GW}(C_D^{new})$ 。接着将 $\{C_D, R_D, HID\}$ 保存在自己的数据库当中。主网关将 $\{C_D, R_D, HID\}$ 通过安全信道广播至其他网关, 其他网关也保存至自己的数据库中, 实现用户信息数据的共享。

c) 主网关将 $\{C_D, R_D\}$ 广播至其他网关实现数据共享后, 将通过安全信道将挑战应答机制对 $\{C_D, R_D\}$ 发送给用户设备, 用户设备收到信息后, 立即保存至自己本地设备中, 供登录和密钥协商过程中使用。

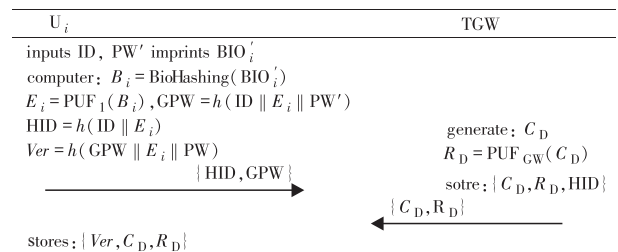


图 2 用户设备注册阶段

Fig. 2 User device registration stage

3.3 传感器设备注册阶段

传感器设备注册阶段流程如图 3 所示, 具体步骤如下:

a) 每个传感器设备拥有自己的身份标识 SID, 所以注册时传感器首先计算 $S_D = PUF_2(SID)$ 。然后通过安全信道将 $\{SID, S_D\}$ 发送给主网关。

b) 主网关拥有自己的主密钥 y 。所以主网关计算 $K_j = h(SID \parallel S_D \parallel y)$, 随后将 K_j 通过安全信道发送给传感器设备, 保存 $\{SID, S_D\}$ 。

c) 传感器设备收到 K_j 后, 将其保存在自己的设备中, 以供密钥协商过程中使用。

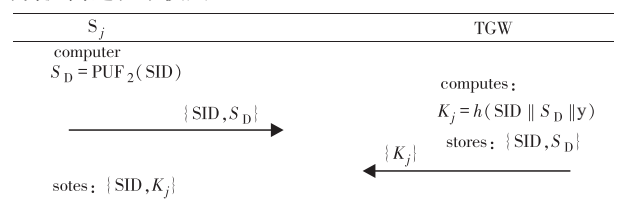


图 3 传感器设备注册阶段

Fig. 3 Sensor device registration phase

3.4 登录认证与密钥协商阶段

用户登录和密钥协商阶段流程如图4所示,具体步骤如下:

a) 用户在自己注册时使用的终端设备上输入自己的身份信息 ID、口令 PW 和生物特征 BIO。设备首先进行本地身份的验证。所以设备计算 $B_i = \text{Biohashing}(BIO)$, $E_i = \text{PUF}_1(BIO)$, $\text{GPW} = h(\text{ID} \parallel E_i \parallel \text{PW})$ 和 $\text{Ver}' = h(\text{GPW} \parallel E_i \parallel \text{PW})$ 。计算完成后将 Ver' 与注册时存储在本地智能卡中的 Ver 进行比对,若 $\text{Ver}' \neq \text{Ver}$ 则会话终止,本地身份验证失败;否则本地身份验证成功。接下来通过可信网关与传感器设备进行会话密钥协商。设备将提取出注册时保存在本地智能卡中的挑战响应 $\{C_D, R_D\}$, 接着用户的设备产生一个时间戳 T_1 , 随即计算 $\text{HID} = h(\text{ID} \parallel E_i)$, $N_1 = \text{HID} \oplus \text{GPW} \oplus R_D$, $N_2 = h(\text{GPW} \parallel N_1 \parallel R_D)$, $N_3 = \text{SID} \oplus N_2 \oplus \text{HID}$, $N_4 = h(N_1 \parallel N_2 \parallel N_3 \parallel \text{HID} \parallel T_1)$ 计算完成后,设备将消息 $M_1 = \{C_D, N_1, N_3, N_4, T_1\}$ 通过公共信道发送给可信网关。其中可信网关有多个,即至少有两个。

b) 当主网关收到消息 M_1 后,首先会进行判断,若主网关当前 CPU 的使用率超过 75% 或者主网关发生故障不能正常工作时,则将消息 M_1 转发至备用网关,备用网关则会根据所收到的消息进行后续的相应计算。若主网关当前 CPU 使用率未超过 75% 且正常工作时,则首先会根据 $|T_1 - T'_1| < \Delta T$ 检查消息的时效性,若无效则会话终止,否则在网关数据库中检索 C_D , 若存在则提取出相应的 R_D 、HID 两个重要参数,用于接下来的计算。计算 $\text{GPW}' = N_1 \oplus \text{HID} \oplus R_D$, $N'_2 = h(\text{GPW}' \parallel N_1 \parallel R_D)$ 和 $N'_4 = h(N_1 \parallel N_2 \parallel N_3 \parallel \text{HID} \parallel T_1)$ 。验证 N_4 是否等于 N'_4 , 若不相等,则数据被篡改,会话终止。若相等则计算 $\text{SID}' = N'_2 \oplus N_3 \oplus \text{HID}$, 在网关数据库中检索 SID' , 若不存在,则传感器设备尚未注册,若存在则提取出相应的重要参数 S_D , 产生当前时间戳 T_2 , 并随即计算 $K'_j = h(\text{SID} \parallel S_D \parallel y)$, $N_5 = R_D \oplus S_D \oplus K'_j$ 和 $N_6 = h(K'_j \parallel N_5 \parallel R_D \parallel S_D \parallel T_2)$, 随后则将消息 $M_2 = \{N_5, N_6, T_2\}$ 通过公共信道发送给相应的传感器设备。

c) 当传感器设备收到消息 M_2 后,首先会根据 $|T_2 - T'_2| <$

ΔT 检查消息的时效性,若无效则会话终止,否则随即计算 $S_D = \text{PUF}_2(\text{SID})$, $R'_D = N_5 \oplus S_D \oplus K'_j$, $N'_6 = h(K'_j \parallel N_5 \parallel R'_D \parallel S_D \parallel T_2)$, 验证 N'_6 与 N_6 是否相等,若不相等,则会话终止,否则产生一个随机数 R , 生成会话密钥 $\text{SK} = h(R'_D \parallel h(S_D \parallel R))$, $N_7 = h(R_D \parallel \text{SK})$, $N_8 = R \oplus S_D \oplus K'_j$, $N_9 = h(R \parallel N_7 \parallel N_8)$ 。随后将消息 $M_3 = \{N_7, N_8, N_9\}$ 通过公开信道发送给此前发送到传感器设备的网关。

d) 当网关收到消息 M_3 后,随即计算 $R' = N_8 \oplus S_D \oplus K'_j$, $N'_9 = h(R' \parallel N_7 \parallel N_8)$, 验证 N'_9 与 N_9 是否相等,若不相等,则会话终止,否则验证通过。产生一个随机数(随机挑战) C_D^{new} , 计算 $R_D^{\text{new}} = \text{PUF}_{\text{GW}}(C_D^{\text{new}})$, $N_{10} = h(R' \parallel S_D) \oplus R_D \oplus \text{GPW}'$, $N_{11} = (C_D^{\text{new}} \parallel R_D^{\text{new}}) \oplus \text{HID} \oplus \text{GPW}'$, $N_{12} = h(h(R' \parallel S_D) \parallel (C_D^{\text{new}} \parallel R_D^{\text{new}} \parallel N_{10} \parallel N_{11}))$ 。随后设备将消息 $M_4 = \{N_7, N_{10}, N_{11}, N_{12}\}$ 通过公共信道发送到用户设备。

e) 当用户设备收到消息 M_4 后,用户设备计算 $h(R' \parallel S_D)^* = N_{10} \oplus \text{GPW} \oplus R_D$, $(C_D^{\text{new}} \parallel R_D^{\text{new}}) = N_{11} \oplus \text{HID} \oplus \text{GPW}$ 。 $N'_{12} = h(h(R' \parallel S_D)^* \parallel (C_D^{\text{new}} \parallel R_D^{\text{new}}) \parallel N_{10} \parallel N_{11})$, 验证 N'_{12} 与 N_{12} 是否相等,若不相等则会话终止,否则验证通过,随后生成会话密钥 $\text{SK} = h(h(R' \parallel S_D) \parallel R_D)$ 。计算 $N'_7 = h(R_D \parallel \text{SK})$, 验证 N'_7 与 N_7 是否相等,若不相等则会话终止,否则分别将 $\{C_D, R_D\}$ 更新为 $\{C_D^{\text{new}}, R_D^{\text{new}}\}$ 。之后,产生一个随机数 r , 计算 $N_{13} = r \oplus \text{HID} \oplus R_D^{\text{new}}$ 和 $N_{14} = h(r \parallel \text{HID} \parallel R_D^{\text{new}})$, 随即将消息 $M_5 = \{N_{13}, N_{14}\}$ 通过公共信道发送给用户发送消息的网关。

f) 当网关收到消息后,计算 $r' = N_{13} \oplus \text{HID} \oplus R_D^{\text{new}}$, $N'_{14} = h(r' \parallel \text{HID} \parallel R_D^{\text{new}})$, N'_{14} 与 N_{14} 是否相等,验证通过后,网关则根据 HID 将 $\{C_D, R_D\}$ 更新为 $\{C_D^{\text{new}}, R_D^{\text{new}}\}$ 。之后,当前网关通过安全信道将 $\{\text{HID}, C_D^{\text{new}}, R_D^{\text{new}}\}$ 广播给其他网关,其他网关则在数据库根据 HID 将 $\{C_D, R_D\}$ 更新为 $\{C_D^{\text{new}}, R_D^{\text{new}}\}$, 至此完成会话密钥的协商过程。

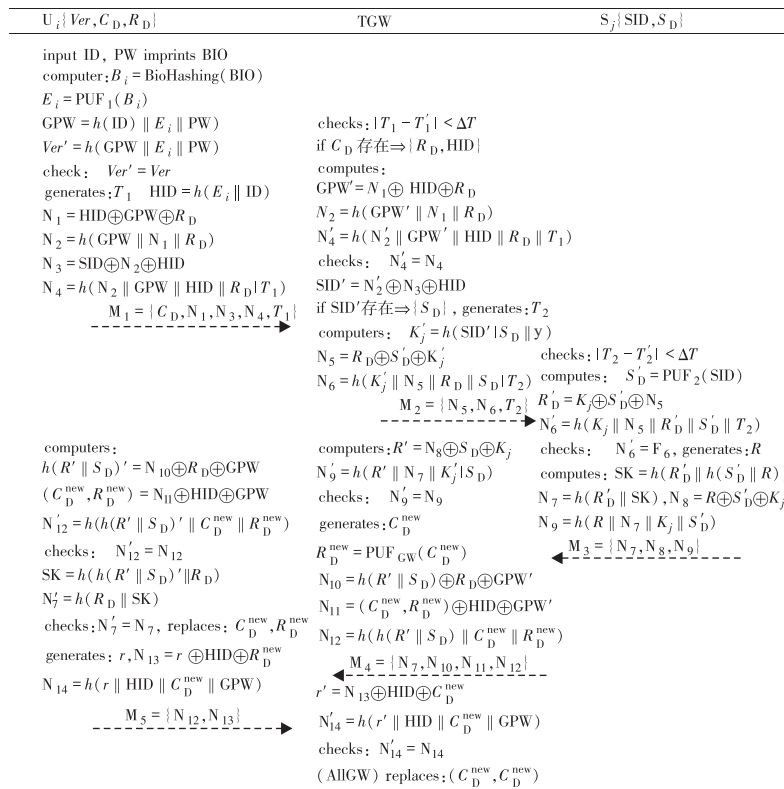


图4 用户登录和密钥协商阶段

Fig. 4 User login and key negotiation phase

3.5 用户口令更新阶段

a) 用户使用注册时的终端设备, 输入自己的身份标识 ID、口令 PW 和生物特征 BIO。设备首先进行本地身份的验证。计算 $B_i = \text{Biohashing}(\text{BIO})$, $E_i = \text{PUF}_1(\text{BIO})$, $\text{GPW} = h(\text{ID} \parallel E_i \parallel \text{PW})$ 和 $\text{Ver}' = h(\text{GPW} \parallel E_i \parallel \text{PW})$ 。验证 Ver 与 Ver' 是否相等, 若不相等则本地身份验证失败, 否则本地身份验证成功。

b) 身份验证通过后, 用户输入新的用户口令 PW^{new} , 计算 $\text{GPW} = h(\text{ID} \parallel E_i \parallel \text{PW}^{\text{new}})$ 和 $\text{Ver}^{\text{new}} = h(\text{GPW} \parallel E_i \parallel \text{PW}^{\text{new}})$ 。计算完成之后, 将 Ver^{new} 保存在本地设备中, 以供下次登录时使用。

3.6 用户注销阶段

a) 用户输入自己的个人信息 ID、口令 PW 和生物特征 BIO。设备首先进行本地身份的验证。设备计算 $B_i = \text{Biohashing}(\text{BIO})$, $E_i = \text{PUF}_1(\text{BIO})$, $\text{GPW} = h(\text{ID} \parallel E_i \parallel \text{PW})$ 和 $\text{Ver}' = h(\text{PW} \parallel E_i \parallel \text{PW})$ 。计算完成后将 Ver' 与注册时存储在本地智能卡中的 Ver 进行比对, 若 $\text{Ver}' \neq \text{Ver}$ 则会话终止, 本地身份验证失败; 否则本地身份验证成功。接下来用户设备将提取出注册时保存在本地智能卡中的挑战响应对 $\{C_D, R_D\}$, 接着用户的设备产生一个时间戳 T_1 , 随即计算 $\text{HID} = h(\text{ID} \parallel E_i)$, $N_1 = \text{HID} \oplus \text{GPW} \oplus R_D$, $N_2 = h(\text{GPW} \parallel N_1 \parallel R_D)$, $N_3 = h(N_1 \parallel N_2 \parallel \text{HID})$, 计算完成后, 设备将注销请求和 $M_1 = \{C_D, N_1, N_3, T_1\}$ 通过公共信道发送给可信网关。

b) 当主网关收到消息 M_1 后, 首先会进行判断, 若主网关当前 CPU 的使用率超过 75% 或者主网关发生故障不能正常工作时, 则将消息 M_1 转发至备用网关, 备用网关则会根据所收到的消息进行后续的相应计算。当主网关当前 CPU 使用率未超过 75% 且正常工作时, 则首先会根据 $|T_1 - T'_1| < \Delta T$ 检查消息的时效性, 若无效则会话终止, 否则在网关数据库中检索 C_D , 若存在则提取出相应的 R_D 、HID 两个重要参数, 用于接下来的计算。计算 $\text{GPW}' = N_1 \oplus \text{HID} \oplus R_D$, $N'_2 = h(\text{GPW} \parallel N_1 \parallel R_D)$ 和 $N'_3 = h(N_1 \parallel N_2 \parallel \text{HID})$ 。验证 N_3 是否等于 N'_3 , 若不相等, 则数据被篡改, 会话终止, 否则验证通过。

c) 当验证通过之后, 当前网关首先将 HID 和注销请求通过安全信道广播给其他网关, 其他网关根据 HID 删除 $\{C_D, R_D\}$, 删除数据库中的该条记录。完成之后, 当前网关也在本地数据库中删除该条记录。若用户想要重新访问传感器, 可通过注册过程, 重新向网关进行注册。

4 安全性分析

4.1 基于随机预言模型 (real-or-random, ROR) 的安全证明

本节通过使用 ROR 模型^[21]从被动/主动攻击者的角度评估协议的会话密钥语义安全性。在展示协议的 SK 安全性之前, 首先介绍 ROR 模型。

在协议中有用户 U_i 、网关/(多网关) (TGW) 和传感设备 (S_j) 三个参与者。表 2 列出了用于 ROR Oracle 模型的必要查询, 例如 $\text{reveal}(\cdot)$ 、 $\text{corrupt}(\cdot)$ 、 $\text{send}(\cdot)$ 、 $\text{execute}(\cdot)$ 和 $\text{test}(\cdot)$, 以证明数学 (正式) 的安全分析。此外, 还使用了“物理不可克隆函数 $\text{PUF}(\cdot)$ ”和“抗碰撞哈希函数 $\text{hash}(\cdot)$ ”作为随机 oracle。广泛使用的 Zipf 定律^[22]被用于证明本文协议的 SK 安全性。

定理 1 $\text{Adv}_A^{\text{AKP}}$ 表示攻击者 A 在破坏 AKP 协议的 SK 安全性方面的能力。那么, 本文可以得出

$$\text{Adv}_A^{\text{AKP}} \leq \frac{q_h^2}{|\text{hash}|} + \frac{q_p^2}{|\text{PFU}|} + 2\max\{C \cdot q_{\text{send}}^s, \frac{q_s}{2^{l_1}}, \frac{q_s}{2^{l_2}}\}$$

其中: q_{send} 、 q_h 、 hash 和 q_p 分别是 $\text{send}(\cdot)$ 查询、哈希函数 $h(\cdot)$

的范围空间、hash 查询的数量和 $\text{PUF}(\cdot)$ 的范围空间。此外, s 、 C 、 l_n 和 l_m 是 Zipf 的参数^[22]。

表 2 符号和说明

Tab. 2 Symbols and Descriptions

查询	描述
$\text{send}(\Pi^t, M_i)$	根据 $\text{send}(\cdot)$ 查询, 攻击者 A 通过公共信道向 Π^t 发送消息并接收响应的消息
$\text{corrupt}(\Pi_{U_i}^{t_1}, \Pi_{S_j}^{t_3})$	该查询被认为是节点捕获攻击, A 可以提取出存储在用户设备和传感器中保存的秘密参数
$\text{execute}(\Pi_{U_i}^{t_1}, \Pi_{\text{TGW}}^{t_2}, \Pi_{S_j}^{t_3})$	通过该查询, A 可以通过公共信道窃听每个参与者之间传输的消息来执行被动攻击/主动攻击
$\text{reveal}(\Pi^t)$	A 可以通过使用该查询猜测泄露出用户和传感器之间协商出的会话密钥 SK 该查询不模拟攻击者的能力, 而是定义会话密钥的语义安全。该查询只对“新鲜的会话”有用, 且只运行 1 次。如果 Π^t 尚未建立会话密钥或者不是“新鲜的”, 则输出 $\perp$, 否则随机选一个比特 c 。如果 $c=1$, 返回会话密钥, 若 $c=0$, 则返回一个等长的随机串
$\text{test}(\Pi^t)$	

证明 本文提出 5 个游戏的序列, 即 $\text{GM}_i (i \in [0, 4])$ 。本文用 $\text{Adv}_A^{\text{AKP}}$ 表示攻击者 A 在游戏 GM_i 中获胜的概率。所有的 GM_i 描述如下。

游戏 GM_0 : 该游戏基于 A 在本文协议中执行的实际安全攻击。比特 c 是在 GM_0 开始之前随机生成。基于 GM_0 , 得到

$$\text{Adv}_A^{\text{AKP}} = |\text{Adv}_{A, \text{GM}_0}^{\text{AKP}} - 1| \quad (1)$$

游戏 GM_1 : GM_1 认为 A 使用 $\text{execute}(\cdot)$ 执行窃听攻击, 拦截 $\Pi_{U_i}^{t_1}$ 、 $\Pi_{\text{TGW}}^{t_2}$ 和 $\Pi_{S_j}^{t_3}$ 之间公开传输的信息。此外, A 执行 $\text{reveal}(\cdot)$ 和 $\text{test}(\cdot)$ 查询以推导出 SK。这些查询的输出决定了 A 是否获得敏感信息和 $\Pi_{U_i}^{t_1}$ 与 $\Pi_{S_j}^{t_3}$ 之间协商出的会话密钥 $\text{SK} = h(R_D \parallel h(S_D \parallel R))$ 。为了推导出 SK, A 需要随机数 $\{R\}$ 和秘密参数 $\{R_D, \text{GPW}\}$ 。因此, A 通过执行窃听攻击来赢得游戏 GM_1 的概率根本没有增加, 可以得出

$$|\text{Adv}_{A, \text{GM}_1}^{\text{AKP}} - \text{Adv}_{A, \text{GM}_0}^{\text{AKP}}| = 0 \quad (2)$$

游戏 GM_2 : 该游戏中, 攻击者 A 通过 $\text{send}(\cdot)$ 和 hash 查询模拟主动攻击和被动攻击。在游戏中, A 可以通过窃听在密钥协商过程中公开信道中传输的数据 $\{M_1, M_2, M_3, M_4, M_5\}$ 。所有消息通过哈希生成或与哈希函数异或而成, 随机数 r 和 R 通过两个秘密参数异或传输, 或通过哈希函数保护。根据生日悖论理论^[23], 可以得出

$$|\text{Adv}_{A, \text{GM}_2}^{\text{AKP}} - \text{Adv}_{A, \text{GM}_1}^{\text{AKP}}| \leq \frac{q_h^2}{2|\text{hash}|} \quad (3)$$

游戏 GM_3 : 该游戏中是 GM_2 的一个扩展, 模拟的是 $\text{PUF}(\cdot)$ 查询。根据 GM_2 的类似分析过程, 基于 ROR 甲骨文模型的安全 $\text{PUF}(\cdot)$ 函数的结果如下:

$$|\text{Adv}_{A, \text{GM}_3}^{\text{AKP}} - \text{Adv}_{A, \text{GM}_2}^{\text{AKP}}| \leq \frac{q_h^2}{2|\text{PUF}|} \quad (4)$$

游戏 GM_4 : 该游戏中, GM_4 模拟 $\text{corrupt}(\cdot)$ 查询。A 可以通过功率分析攻击提取出保存在用户设备当中的参数 $\{Ver, C_D, R_D\}$ 。需要注意的是 $Ver = h(\text{GPW} \parallel E_i \parallel \text{PW})$, $R_D = \text{HID} \oplus \text{GPW} \oplus N_1$, C_D 公开传输且每次更新。此外, A 可以通过节点捕获攻击获取到保存在传感器中的 $\{SID, K_j\}$ 。需要注意的是 $SID = N_3 \oplus N_2 \oplus \text{HID}$, $K_j = N_5 \oplus S_D \oplus R'_D$ 。然而 GM_4 在计算上不可能让 A 在没有生物特征和 ID 的情况下通过 $\text{send}(\cdot)$ 查询推导出口令 PW。此外, 因为 A 猜测出生物特征密钥和 PUF 生成的秘密值的概率分别约为 $1/2^{l_1}$, $1/2^{l_2}$ 。所以 A 无法区分生物特征和 PUF 生成的秘密值。因此, 如果离线密码或生物识别猜测攻击没有成功实现, GM_3 和 GM_4 是无法区分的。因此, 可以得到

$$|\text{Adv}_{A, \text{GM}_4}^{\text{AKP}} - \text{Adv}_{A, \text{GM}_3}^{\text{AKP}}| \leq \{C \cdot q_{\text{send}}^s, \frac{q_s}{2^{l_1}}, \frac{q_s}{2^{l_2}}\} \quad (5)$$

在 $GM_0 \sim GM_4$ 成功执行后, A 尝试使用 $\text{test}(\cdot)$ 查询来猜测有效的 c 以赢得游戏。因此,可以得到

$$Adv_{A, GM_4}^{AKP} = \frac{1}{2} \quad (6)$$

通过结合式(1)~(6),可以得到

$$Adv_A^{AKP} \leq \frac{q_h^2}{|\text{hash}|} + \frac{q_p^2}{|\text{PUF}|} + 2\max\{C \cdot q_{\text{send}}, \frac{q_s}{2^{l_1}}, \frac{q_s}{2^{l_2}}\} \quad (7)$$

4.2 ProVerif 仿真工具安全证明

基于文献[24],利用 ProVerif 协议仿真工具对该协议进行了安全性验证。ProVerif 是一种专为自动分析密码协议安全性设计的工具,其在实际应用中的有效性已被广泛验证。

在 Dolev-Yao 模型下,该协议由用户、网关和传感器设备三个进程并行运行。仿真结果如图 5 所示。结果首先显示该协议能够在弱口令 PW 和弱生物特征 BIO 的条件下执行。其次,仿真结果表明,该协议成功实现了用户与网关、网关与传感器之间的双向认证。最后,仿真结果确认该协议的会话密钥是安全的,并且能够抵御常见的攻击类型。因此,通过 ProVerif 仿真工具的形式化安全验证,证明了该协议在 Dolev-Yao 模型下是安全的。

```

Verification summary:
Weak secret PW is true.
Weak secret BIO is true.
Query inj-event(endUG(use_1)) ==> inj-event(beginUG(user_1)) is true.
Query inj-event(endGU(TGM_1)) ==> inj-event(beginGU(TGW_1)) is true.
Query inj-event(endGS(TGW_1)) ==> inj-event(beginGS(TGW_1)) is true.
Query inj-event(endSG(SN_1)) ==> inj-event(beginSG(SN_1)) is true.
Query inj-event(endGUI(TGW_1)) ==> inj-event(beginGUI(TGW_1)) is true.
Query not attacker(sku[]) is true.
Query not attacker(sks[]) is true.

```

图 5 代码仿真结果

Fig. 5 Code simulation results

4.3 安全分析

1) 离线口令猜测攻击

针对以口令为主的身份认证协议,离线口令猜测攻击是一个主要的安全威胁。根据攻击者模型,攻击者可以通过侧信道攻击获取用户智能卡中的参数 $\{Ver, C_D, R_D\}$, 可以获取公共信道中的参数。口令的运算只在本地身份验证中出现 $Ver = h(h(ID \parallel \text{PUF}_1(\text{BIO}) \parallel \text{PW}))$ 。攻击者无法通过攻破和公共信道中获取的数据得出身份标识 ID 和 $\text{PUF}_1(\text{BIO})$, 其中 BIO 是生物特征,攻击者不可能从口令空间中猜测到用户的口令。所以该协议能够抵抗离线口令猜测攻击。

2) 用户匿名性

用户的匿名性是指用户无法被攻击者追踪到。也就是用户不可能两次发出同一参数。本文协议中用户发送的消息 $M_1 = \{C_D, N_1, N_3, N_4, T_1\}$, 其中 C_D 是随机数, $\{N_1, N_3, N_4\}$ 中的每个消息都有 R_D 的参与。因 R_D 是经过 $\text{PUF}_2(C_D)$ 生成的,所以具备随机数的特性。同理,消息 $M_5 = \{N_{13}, N_{14}\}$ 中因随机数 r 的参与,该消息也具备随机数的特性。所以用户端发出的每个消息都具备随机性,攻击者无法通过公共信道中获取的消息计算出具有用户标识特性的信息。所以该协议满足用户的匿名性。

3) 抵抗会话密钥泄露安全

该协议中会话密钥是由哈希函数生成,且由于随机数的参与,具备随机性。协议中会话密钥为 $SK = h(R'_D \parallel h(S_D \parallel R))$, 而攻击者无法仿造出 $\{R_D, S_D\}$, 同时也无法仿造出随机数 R , 攻击者也无法通过从公共信道中获取的数据恢复出 $\{R_D, S_D\}$ 和 R 。所以该协议能够抵抗会话密钥泄露安全。

4) 前向/后向安全性

根据无线传感器网络安全需求,身份认证协议应该满足传感器网络的前向或后向安全性。在本文协议中,用户、网关和传感器完成双向认证后,生成一个会话密钥 SK 用于加密后续传输的机密数据。而 SK 是由各通信实体在每次认证过程中生成的随机数加密生成的,所以 SK 在每次认证过程中呈动态随机变化的。如果未来某个时刻通信密钥被泄露,之前的通信内容不会被解密,如果某时刻会话密钥被泄露,未来的通信内容也不会被解密。此外,SK 只因参与 N_7 哈希运算,不涉及其他任何运算,即使 SK 丢失也不会影响之前或未来的会话密钥安全。因此,当用户、传感器加入或者离开后,攻击者不可能获得之前或者之后传输数据的 SK。因此,该协议可以满足前向/后向安全性。

5) 抵抗临时秘密值泄露攻击。该协议中,有两个临时秘密值 R 和 r 。当 R 泄露时,因为 $R = N_8 \oplus S_D \oplus K_j$,攻击者无法得到 S_D, K_j 。当 r 泄露时,因为 r 的计算过程是 $r = N_{13} \oplus \text{HID} \oplus R_D^{\text{new}}$,攻击者无法知道 $\text{HID}, R_D^{\text{new}}$,所以无法计算出 $\text{HID}, R_D^{\text{new}}$ 。所以该协议可以抵抗临时秘密值泄露攻击。

6) 双向认证

该协议中,用户、网关和传感器每次收到消息后,都会进行消息的合法性认证。都要通过合法性验证才进行后续运算,而每个验证消息的生成都涉及两个或两个以上的秘密参数,所以攻击者无法恢复,也无法仿造。

a) 可信网关认证用户及传感器。针对用户身份,首先通过 C_D 检索初步验证用户的合法性,通过验证 N_4 进一步验证用户的身份。为了通过 F_5 的验证,需要知道 GPW 和 R_D 。显然,依据 PUF 的唯一性,假冒用户无法计算 GPW 和 R_D ,进而无法通过 N_4 的验证。针对传感器身份,利用 N_9 计算中 S_D 因子验证了传感器身份。因为,只有 TGW 与 S_j 才可能拥有 S_D 。

b) 用户认证可信网关及传感器。用户收到可信网关的消息 M_4 后,通过验证 N_{12} 可以验证可信网关的身份。因为只有用户与可信网关掌握 GPW 与 HID ,并且 GPW 不能恢复和计算 (PUF 的唯一性)。由于可信网关的完全可信且验证了传感器身份,所以用户间接验证了传感器身份。

c) 传感器认证可信网关与用户。传感器收到消息 M_2 后,通过 N_6 验证可信网关的身份。因为只有网关和传感器知悉 K_j 与 S_D 才能计算出 R_D ,继而验证 N_6 ,且计算需要可信网关的主密钥 y 以及 PUF_2 的支持,这些都不可能由攻击者同时获取到。所以,传感器验证了可信网关的身份,考虑到可信网关的完全可信,间接证明了用户身份。

由上可知,该协议的三个实体实现了相互认证。

7) 重放攻击

重放攻击是一种非常流行的简单攻击模式。根据攻击者模型,攻击者可以截获并且转发在公共网络中传输的数据,以实现欺骗的目的。在该协议中用户向网关,网关向传感器发送消息时都通过时间戳参与完整性校验,且收到信息后接收方首先验证时间戳的新鲜性。如果收到的时间戳不新鲜,接收方拒绝请求并终止会话。传感器向网关、网关向用户发送信息,因为随机数的存在,可以保证会话的新鲜性。所以该协议可以抵抗重放攻击。

8) 抵抗传感器节点捕获攻击

当传感器节点被捕获之后,攻击者可以通过侧信道攻击提取出传感器中所保存的参数。该协议中,攻击者获得 $\{SID, K_j\}$, 只能恢复出 $N_2 \oplus \text{HID}$ 与 $R_D \oplus S_D$ 。由于 S_D 由 PUF 生成,所以攻击者无法仿造出 S_D ,攻击者也无法恢复出 $R_D = N_5 \oplus S_D \oplus K_j$,所以也无法恢复出会话密钥;同样,只有 SID 和 K_j ,攻

击者无法恢复出用户与网关的隐私数据,无法进行假冒传感器向网关发送消息以及用户、网关的假冒等。

9) 长期秘密值泄露攻击

在网关中,有一个秘密值 y ,长期保存在网关当中,负责传感器的注册。当 y 被泄露时,由于攻击者无法获得由 PUF_{GW} 生成的 S_D ,所以攻击者无法计算出 $K'_j = h(SID \parallel S_D \parallel y)$,也无法恢复出会话密钥,所以该协议可以抵抗长期秘密值泄露攻击。

10) 抵抗窃听攻击

攻击者可以拦截来自公共信道的消息,但是每个认证消息和会话密钥 SK 都受哈希函数的保护,所以攻击者无法从公共信道传输的信息中获取有用的信息来进行假冒攻击或者恢复出会话密钥。该协议可以抵抗窃听攻击。

11) 抵抗内部攻击

用户在注册时未将其生物特征或口令泄露给可信网关,网关无从获得用户的隐私信息。当网关中内部人员攻破到长期存储的某一个长期参数时,其也无法恢复出当前的会话密钥。所以该协议可以抵抗网关假冒攻击和内部攻击。

12) 抵抗中间人攻击

攻击者可以拦截来自公共信道的消息,但由于其中的秘密参数都是未知的攻击者。攻击者无法生成有效的消息欺骗任意两个通信方。所以,该协议可以抵抗中间人攻击。

13) 抵抗口令更新阶段攻击

在该协议中,由于在注册阶段,用户口令并未向网关发送,所以口令更新时只在本地进行口令更新,不存在公共通道中传输敏感数据。该协议可以抵抗口令更新阶段的攻击。

14) 满足三因子安全性

三因素安全是指,即使攻击者获得了用户的两个身份验证因素,他们仍然无法获得第三个身份验证因素,也就无法成功假冒用户。以下三种情况详细分析了协议中的三因素安全。

a) 当攻击者获得了用户的智能卡参数和生物特征时,无法获得用户的口令和 ID。攻击者利用获得的数据计算出 $B_i = \text{BioHashing}(\text{BIO})$,但是由于攻击者没有 PUF,无法计算 $E_i = \text{PUF}_1(\text{BIO})$,继而无法计算 $\text{GPW} = h(\text{ID} \parallel E_i \parallel \text{PW})$ 与 $\text{HID} = h(\text{ID} \parallel E_i \parallel \cdot)$ 。所以无法计算或成功猜测出 PW 以及 ID 的值。

b) 当攻击者获得了用户的智能卡参数、口令和 ID 时,无法获得用户的生物特征。因为攻击者没有 PUF,无法得到 E_i ,所以利用已有数据无法计算 $\text{GPW} = h(\text{ID} \parallel E_i \parallel \text{PW})$, $\text{HID} = h(\text{ID} \parallel E_i)$, $N_2 = h(\text{GPW} \parallel N_1 \parallel R_D)$, $N_1 = \text{HID} \oplus \text{GPW} \oplus R_D$,更无法计算出生物特征 BIO 或者 E_i 。

c) 当攻击者获得了用户的生物特征、用户的口令和 ID 时,无法得出用户本地存储的参数。由于攻击者没有 PUF,所以无法恢复出 E_i ,攻击者无法计算出 $\text{GPW} = h(\text{ID} \parallel E_i \parallel \text{PW})$, $\text{HID} = h(\text{ID} \parallel E_i)$,所以也无法计算出本地存储的参数 Ver 且由于 C_D 与 R_D 是有可信网关在注册时生成,任何非可信网关实体都无法恢复出这对参数。所以,攻击者无法恢复出智能卡中保存的参数。

现有的三因子认证协议多数无法实现三因子安全性,这是由于当生物特征和智能卡被攻破时,攻击者可以根据智能卡中存储的验证值验证输入口令与生物特征的有效性,进而猜测用户口令。在本文协议中,生物特征经过 PUF 处理,所以攻击者无法克隆 E_i ,无法进一步计算出其他参数,所以本文协议可以满足三因子安全性。

5 对比分析

传感器设备大多存在物理尺寸小、存储资源不足、计算资源有限等情况。为了评估该协议在计算开销、存储开销和安全

特性方面的具体情况,本章在相同的性能基准下将所提协议与文献[24~27]在计算开销、通信开销、存储开销和安全性方面进行对比。

5.1 计算开销对比

参考文献[28]中所定义的运算时间,规定 hash 运算、对称加密/解密、模糊提取运算、生物哈希运算、PUF 模块等的 1 次运算时间分别为 $T_H \approx 0.0026 \text{ ms}$ 、 $T_{sym} \approx 0.00325 \text{ ms}$ 、 $T_{fuzzy} \approx 1.989 \text{ ms}$ 、 $T_b \approx 0.005 \text{ ms}$ 、 $T_p \approx 0.00015 \text{ ms}$ 。

该协议中,用户端使用 1 次 BioHashing、1 次 PUF 和 9 次 hash 函数,分别表示为 $1T_b$ 、 $1T_p$ 、 $9T_H$ 。所以用户端的计算开销为 $1T_b + 1T_p + 9T_H \approx 0.02855 \text{ ms}$ 。同理,在 TGW 中的计算开销为 $1T_p + 8T_H \approx 0.02095 \text{ ms}$ 。传感器中的计算开销为 $1T_p + 5T_H \approx 0.01315 \text{ ms}$ 。三个实体完成一次会话密钥协商的总计算开销为 $1T_b + 3T_p + 22T_H \approx 0.0626 \text{ ms}$ 。在统一的性能基准和计算方式下,对比五个协议在用户端、网关端和传感器端的计算开销如图 6~8 所示。图 9 表示完成一次会话密钥协商总计算开销的对比情况。

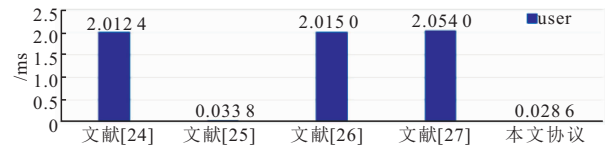


图6 用户端计算开销对比

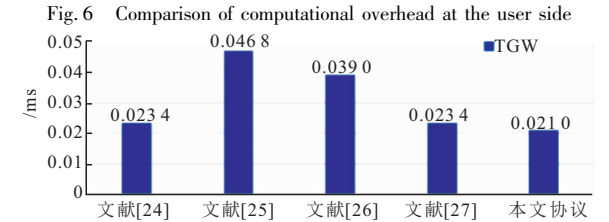


图7 网关计算开销对比

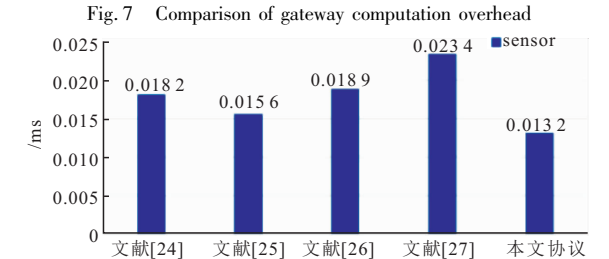


图8 传感器计算开销对比

Fig. 8 Comparison of sensor computation overhead

根据认证过程可知,文献[24,26,27]在用户端本地身份验证过程中使用模糊提取函数,导致三个协议在用户端开销较大,进一步提高了总计算开销。文献[29]在本地登录和密钥协商阶段使用轻量级运算,其用户端计算开销较小。但是由于设计中存在计算冗余,导致该协议在网关的计算开销最大。本文协议在身份验证和密钥协商阶段使用轻量级运算,并且设计巧妙,使得在用户、网关、传感器和总计算开销方面都达到最优,并且在用户端和总计算开销方面远优于文献[24,26,27]。

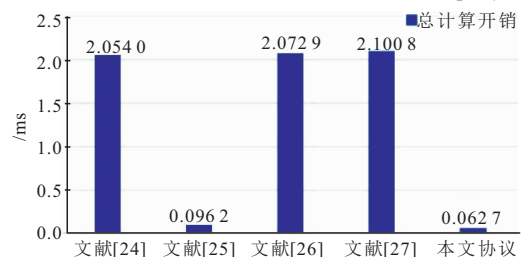


图9 总计算开销对比

Fig. 9 Comparison of total computational overhead

5.2 存储开销对比

根据文献[30]的数值,本文定义随机数、hash 函数、身份ID/口令/生物识别、时间戳和对称加密/解密的输出长度分别为 32 bit、160 bit、32 bit、32 bit 和 128 bit。根据上述定义的数值,计算 5 个协议存储和通信开销,并进行对比。

在存储开销方面只比较用户端和传感器两个实体。因可信网关是可信第三方,属于资源不受限实体,故不考虑网关的存储开销。该协议中,用户端存储用于本地身份验证的参数 $\{Ver, C_D, R_D\}$, 开销为 224 bit。传感器存储了身份标识和参数 $\{SID, K_j\}$, 开销为 192 bit。所以总的存储开销为 416 bit。

通信开销为公开信道中传输参数的比特值。该协议在公开信道中所传输的参数长度分别为 $M_1 = \{C_D, N_1, N_3, N_4, T_1\} = 32 + 160 + 160 + 160 + 32 = 544$ bit, $M_2 = \{N_5, N_6, T_2\} = 160 + 160 + 32 = 352$ bit, $M_3 = \{N_7, N_8, N_9\} = 160 + 160 + 160 = 480$ bit, $M_4 = \{N_7, N_{10}, N_{10}, N_{11}\} = 160 + 160 + 160 + 160 = 640$ bit, $M_5 = \{N_{13}, N_{14}\} = 160 + 160 = 320$ bit。所以总通信开销为 2 336 bit。

在统一的性能基准和计算方式下,其他 4 个协议使用上述定义数值,得出各自的存储开销和通信开销,具体数值如图 10、11 所示。该协议由于在用户和网关之间使用挑战响应对,极大减小了用户设备中需要存储的参数。在传感器设备中只保存了一个身份标识和一个密钥。所以该协议在存储开销方面仍是最优的。同时,为了保证协议的安全性,本文协议中的消息在公开信道传输的过程中使用哈希保护或与哈希值异或,导致该协议在通信开销方面相对较大,但是相差的具体数值较小。考虑到该协议在计算开销、存储开销方面都是最优的,而且在后面的安全性对比中也是最优的,所以通信开销的劣势在容忍范围之内。

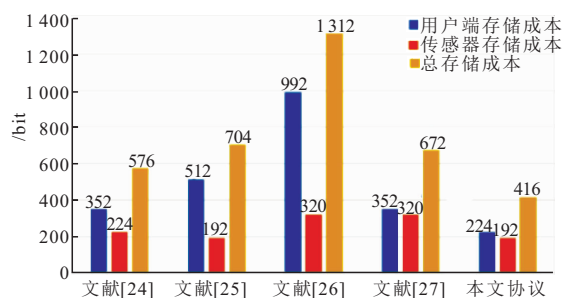


图 10 存储开销对比

Fig. 10 Storage overhead comparison

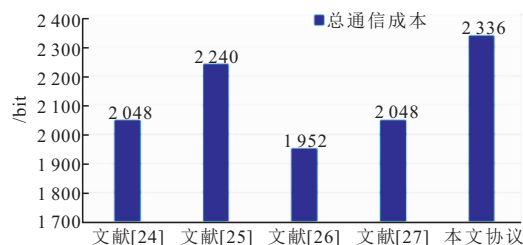


图 11 总通信成本对比

Fig. 11 Comparison of total communication costs

5.3 安全性比较和分析

参考文献[24,31]中的安全漏洞类型和分析方法,将本文协议与相关协议在安全性方面作出对比,如表 3 所示。在表中,“√”表示可以抵制该漏洞或满足安全要求,“×”表示不能。根据表 3,本文协议在安全性方面有着较大优势,满足多种应用场景下的安全需求。

表 3 安全对比

Tab. 3 Safety comparison

协议	文献[24]	文献[25]	文献[26]	文献[27]	本文协议
S1	×	×	√	√	√
S2	×	√	√	×	√
S3	√	√	√	×	√
S4	√	√	√	×	√
S5	√	√	√	√	√
S6	√	√	√	√	√
S7	√	√	√	√	√
S8	√	×	√	√	√
S9	√	√	√	√	√
S10	√	√	√	√	√
S11	√	√	√	√	√
S12	√	√	√	√	√
S13	√	√	√	√	√
S14	√	√	√	×	√

注:S1-离线口令猜测攻击;S2-匿名性;S3-会话密钥泄露攻击;S4-前向/后向安全性;S5-临时秘密值泄露攻击;S6-相互认证;S7-重放攻击;S8-传感器节点捕获攻击;S9-长期秘密值泄露攻击;S10-窃听攻击;S11-内部攻击;S12-中间人攻击;S13-口令更新阶段攻击;S14-三因子安全性。

6 结束语

本文提出了一种面向无线传感器网络的基于 PUF 的轻量级多网关身份认证协议。该协议不仅具有无线传感器网络中轻量级的优点,同时利用 PUF 技术有效解决了离线口令猜测、用户身份追踪以及会话密钥不可伪造等问题,且采用轻量级算法。协议中没有使用任何对称加密或非对称等其他非轻量级加密算法,除使用生物哈希函数、PUF 函数,其余运算都采用哈希和异或操作,适用于计算资源受限诸多场景,比如远程医疗、车联网、工业、农业等。其次该协议中多网关策略扩展了可信网关,解决了单个网关在环境恶劣或计算资源消耗极大的情况下的处理瓶颈问题和单节点故障问题。使得该协议特别适用于计算资源受限的诸多场景。其次通过随机预言模型、ProVerif 协议仿真工具和安全分析证明了该协议的安全性。最后通过与近年相关类似协议进行比较,结果表明其在计算开销、存储开销和安全性方面展现了相对较大的优势。

参考文献:

- [1] Das M L. Two-factor user authentication in wireless sensor networks [J]. *IEEE Trans on Wireless Communications*, 2009, 8(3): 1086-1090.
- [2] Nyang D, Lee M K. Improvement of Das's two-factor authentication protocol in wireless sensor networks [J]. *IACR Cryptology EPrint Archive*, 2009, 2009: 631.
- [3] Cheikhrouhou O, Koubaa A, Boujelben M, et al. A lightweight user authentication scheme for wireless sensor networks [C]// *Proc of ACS/IEEE International Conference on Computer Systems and Applications*. Piscataway, NJ: IEEE Press, 2010: 1-7.
- [4] Yeh H L, Chen T H, Liu Pinchuan, et al. A secured authentication protocol for wireless sensor networks using elliptic curves cryptography [J]. *Sensors*, 2011, 11(5): 4767-4779.
- [5] Amin R, Biswas G P. A secure light weight scheme for user authentication and key agreement in multi-gateway based wireless sensor networks [J]. *Ad hoc Networks*, 2016, 36: 58-80.
- [6] Shi Wenbo, Gong Peng. A new user authentication protocol for wireless sensor networks using elliptic curves cryptography [J]. *International Journal of Distributed Sensor Networks*, 2013, 9(4): 730831.
- [7] Choi Y, Lee D, Kim J, et al. Security enhanced user authentication protocol for wireless sensor networks using elliptic curves cryptography

- [J]. *Sensors*, 2014, 14(6): 10081-10106.
- [8] Dinarvand N, Barati H. An efficient and secure RFID authentication protocol using elliptic curve cryptography [J]. *Wireless Networks*, 2019, 25(1): 415-428.
- [9] Wang Yuanbing, Liu Wanrong, Li Bin. An improved authentication protocol for smart healthcare system using wireless medical sensor network [J]. *IEEE Access*, 2021, 9: 105101-105117.
- [10] Hayouni H. AuthenIoT: a lightweight authentication protocol for the Internet of Things based wireless sensor networks [J]. *EAI Endorsed Trans on Cloud Systems*, 2022, 7(21): 171321.
- [11] Ghafouri Mirsarai A, Barati A, Barati H. A secure three-factor authentication scheme for IoT environments [J]. *Journal of Parallel and Distributed Computing*, 2022, 169: 87-105.
- [12] Das A K, Sutrala A K, Kumari S, *et al.* An efficient multi-gateway-based three-factor user authentication and key agreement scheme in hierarchical wireless sensor networks [J]. *Security and Communication Networks*, 2016, 9(13): 2070-2092.
- [13] Wu Fan, Xu Lili, Kumari S, *et al.* An efficient authentication and key agreement scheme for multi-gateway wireless sensor networks in IoT deployment [J]. *Journal of Network and Computer Applications*, 2017, 89: 72-85.
- [14] Guo Hua, Gao Ya, Xu Tongge, *et al.* A secure and efficient three-factor multi-gateway authentication protocol for wireless sensor networks [J]. *Ad hoc Networks*, 2019, 95: 101965.
- [15] Srinivas J, Mukhopadhyay S, Mishra D. Secure and efficient user authentication scheme for multi-gateway wireless sensor networks [J]. *Ad hoc Networks*, 2017, 54: 147-169.
- [16] Wang Ding, Li Wenting, Wang Ping. Measuring two-factor authentication schemes for real-time data access in industrial wireless sensor networks [J]. *IEEE Trans on Industrial Informatics*, 2018, 14(9): 4081-4092.
- [17] Lee J, Yu S, Park K, *et al.* Secure three-factor authentication protocol for multi-gateway IoT environments [J]. *Sensors*, 2019, 19(10): 2358.
- [18] Dai Cong, Xu Zhongwei. A secure three-factor authentication scheme for multi-gateway wireless sensor networks based on elliptic curve cryptography [J]. *Ad hoc Networks*, 2022, 127: 102768.
- [19] Zhao Xingwen, Li Dexin, Li Hui. Practical three-factor authentication protocol based on elliptic curve cryptography for industrial Internet of Things [J]. *Sensors*, 2022, 22(19): 7510.
- [20] Chen Chen, Guo Hua, Wu Yapeng, *et al.* A novel two-factor multi-gateway authentication protocol for WSNs [J]. *Ad hoc Networks*, 2023, 141: 103089.
- [21] Abdalla M, Fouque P A, Pointcheval D. Password-based authenticated key exchange in the three-party setting [C]// Proc of the 8th International Conference on Theory and Practice in Public Key Cryptography. Berlin: Springer-Verlag, 2005: 65-84.
- [22] Wang Ding, Cheng Haibo, Wang Ping, *et al.* Zipf's law in passwords [J]. *IEEE Trans on Information Forensics and Security*, 2017, 12(11): 2776-2791.
- [23] Boyko V, MacKenzie P, Patel S. Provably secure password-authenticated key exchange using Diffie-Hellman [C]// Advances in Cryptology — EUROCRYPT 2000. Berlin: Springer, 2000: 156-171.
- [24] Yu S, Park Y. A robust authentication protocol for wireless medical sensor networks using blockchain and physically unclonable functions [J]. *IEEE Internet of Things Journal*, 2022, 9(20): 20214-20228.
- [25] Kwon D K, Yu S J, Lee J Y, *et al.* WSN-SLAP: secure and lightweight mutual authentication protocol for wireless sensor networks [J]. *Sensors*, 2021, 21(3): 936.
- [26] Chen C M, Liu Shuangshuang, Li Xuanang, *et al.* A provably-vsecure authenticated key agreement protocol for remote patient monitoring IoMT [J]. *Journal of Systems Architecture*, 2023, 136: 102831.
- [27] Wazid M, Thapliyal S, Singh D P, *et al.* Design and testbed experiments of user authentication and key establishment mechanism for smart healthcare cyber physical systems [J]. *IEEE Trans on Network Science and Engineering*, 2023, 10(5): 2697-2709.
- [28] Huang Wenfeng. ECC-based three-factor authentication and key agreement scheme for wireless sensor networks [J]. *Scientific Reports*, 2024, 14(1): 1787.
- [29] Yang J H. A multi-gateway authentication and key-agreement scheme on wireless sensor networks for IoT [J]. *EURASIP Journal on Information Security*, 2023, 2023(1): 2.
- [30] Sahoo S S, Mohanty S, Sahoo K S, *et al.* A three-factor-based authentication scheme of 5G wireless sensor networks for IoT system [J]. *IEEE Internet of Things Journal*, 2023, 10(17): 15087-15099.
- [31] 王菲菲. 物联网环境下的认证协议研究 [D]. 北京: 北京邮电大学, 2020. (Wang Feifei. Research on authentication protocols in Internet of Things environment [D]. Beijing: Beijing University of Posts and Telecommunications, 2020.)